NOME: LUCAS SANTOS SILVA

RA: 049860

LISTA 1 - 2 BIMESTRE

EXERCÍCIO 1 — Autenticação e autorização Explique, com suas palavras, a diferença entre autenticação e autorização. Apresente um exemplo de uma situação em que um usuário precisa ser autenticado para acessar uma API e outro exemplo em que, além de estar autenticado, ele precisa ter uma permissão específica para realizar uma operação.

Autenticação é provar quem você é, tipo fazer login com usuário e senha. Autorização é ver o que você pode fazer depois de entrar. Exemplo de só autenticação: para ver o seu próprio perfil no app, basta estar logado. Exemplo com permissão: no sistema da faculdade, qualquer aluno logado vê as notas dele, mas só o professor logado pode lançar ou alterar nota. Estar logado não basta, precisa ter a permissão de professor.

EXERCÍCIO 2 — Funcionamento do JWT Descreva o fluxo de autenticação utilizando JWT, desde o envio do usuário e da senha até o acesso a uma rota protegida. Em sua resposta, explique:

- **Qual é a finalidade do token JWT?**
- **Como o cliente envia o token nas próximas requisições?**
- **Para que serve o cabeçalho HTTP Authorization: Bearer?**
- **Por que não devemos colocar senhas ou informações secretas no conteúdo do token?**

O usuário manda usuário e senha para a rota de login. A API confere, e se estiver certo, cria um token JWT e devolve. O token é como uma pulseira de festa: prova que você já passou pela portaria. Nas próximas requisições o cliente manda esse token no cabeçalho Authorization: Bearer <token>. A API confere se o token é verdadeiro e não expirou, e libera a rota protegida. O Authorization: Bearer serve para levar o token em cada pedido, já que a API não guarda quem está logado. Não se coloca senha nem segredo dentro do token porque o conteúdo dele só está codificado, não escondido. Qualquer pessoa que pegar o token consegue ler o que tem dentro. A assinatura só garante que ninguém alterou, não que ninguém leu.

EXERCÍCIO 3 — Status HTTP 401 e 403 Explique a diferença entre os códigos HTTP 401 Unauthorized e 403 Forbidden. Apresente uma situação prática para cada código, considerando uma API que utiliza JWT para proteger suas rotas.

O 401 (Unauthorized) quer dizer “não sei quem você é”: você não mandou o token, ou ele é inválido ou expirou. Exemplo: acessar /api/usuario/perfil sem token. O 403 (Forbidden) quer dizer “sei quem você é, mas você não pode fazer isso”. Exemplo: um aluno logado, com token válido, tenta usar uma rota que só professor acessa.